

E7 Guest System — SaaS Plan (Revised Draft)

Overview

We want to build a white-label visitor management system with the ability to sell subscriptions to churches and businesses. The system covers visitor registration (web-only), SMS-based follow-up, and a dedicated mobile/web admin interface for account management and team coordination — all under a multi-tenant SaaS model.

Two distinct user groups:

- **Account admins and staff** — the people who manage the system. They access features via a web dashboard and/or a dedicated mobile app (CRM, visitor follow-up, messaging, reminders, analytics).
- **Visitors** — the people who check in at a location. They interact exclusively through a browser-based form, accessed via a shared link or QR code. Visitors never use and have no need for the native app.

Main Entities

Entity	Description
Account	Top-level tenant. Created by an org admin; owns all locations, users, and billing.
Account User	Member of an account with limited permissions (view visitors, send messages).
Account Admin	Extends Account User with full control over account settings, form configuration, and user management.
Account Location	A specific entry point, web URI, or virtual form. Not necessarily tied to a physical address.
Visitor / Guest	A person who scans a QR code or visits a form URL to register at a location. No app install required — all interaction is via the browser.
System Admin	Platform-level admin who manages accounts, billing, and abuse reports.
Message Thread	Ongoing conversation between a visitor (via web form or SMS) and an account user/staff member (via app or web).

Requirements

- **Web UI** — Vite/React PWA frontend deployed to Netlify for account signup, form configuration, and admin dashboards. This is also the only interface visitors ever see (via unique account URL form/welcome pages).
- **Mobile App** — Expo-based iOS/Android app exclusively for account admins and staff. Provides CRM, visitor management, messaging, reminders, and analytics on the go. Visitors do not use this app.
- **Backend** — Convex for real-time data, auth, server functions, and subscriptions.

- **SMS** — Visitor messages sent via SMS gateway. Staff reply through the web or mobile app to keep personal numbers private.
 - **QR Codes** — Per-location QR codes that link to a visitor opt-in registration form.
 - Account admin can configure what the visitor data forms collect & minimal UI customization (theme, welcome message, etc).
 - Standard fields include: names, party size, local/moving status, friends/family at church, reason for visit, prayer requests, follow-up request.
 - **Opt-Out / Data Rights** — Visitors can reply with common keywords to opt out of follow-ups or request data removal. GDPR and similar regulations require special attention for churches vs. businesses and for physical location data collection (see § Legal & Compliance).
-

Core Use-Case Flow

For visitors (web only):

1. Visitor scans a QR code or opens a shared link → browser form appears.
2. Visitor fills out the form and opts in to follow-up messages.
3. System sends an automated SMS response using the location admin's template.
4. Visitor optionally replies by SMS to engage in follow-up messaging.

For account admins and staff (app or web):

5. **Account creation** — Admin signs up with email + password, Google, or Apple OAuth.
 6. **Location & form setup** — Admin creates a location, selects form fields from common templates (or builds a custom form), configures an automatic SMS reply template (max 140 chars), and shares the URI or QR code where visitors will find it.
 7. **Staff invitations (optional)** — Admin creates additional account users via invitation email; can grant admin privileges.
 8. **Activity logging & notifications** — System logs each visitor registration and sends a push notification to registered account users.
 9. **Staff follow-up** — Account users (admins or staff) open the app or web UI to:
 - View contacts, activity log, or notifications.
 - Add arbitrary notes to a visitor/contact profile.
 - Set reminders to check back with individual visitors (or general reminders to review recent visitors).
 - Update contact information and status.
-

Kaizen Enhanced Additions

The original draft identified the core concept correctly but left out several areas critical to building, launching, and operating a real SaaS product. The sections below address those gaps.

1 — Subscription & Pricing Model

The draft mentions SaaS but defines no revenue model. A three-tier structure is proposed below. Detailed costs and reasoning are in the companion file [pricing-addendum.md](#).

Tier	Price	Highlights
Starter (Free)	\$0/mo	1 location, up to 100 visitors & 300 SMS messages/month, basic form fields & customization, 1 admin user, email support
Pro	\$29/mo (billed annually)	Up to 5 locations, 1,000 visitors & 3,500 SMS messages/month, custom form fields + conditional logic, up to 5 staff users, automated SMS sequences, basic analytics
Enterprise	\$99/mo (billed annually)	Unlimited locations & visitors, advanced role management, white-label branding (logo, colors, custom domain), full analytics + CSV/PDF export, priority support

- **Billing:** Stripe integration for subscription lifecycle (trial, upgrade/downgrade, cancellation, proration).
- (deferred pending difficulty investigation) **Church discount:** 501(c)(3) verified organizations receive 20% off Pro and Enterprise tiers.
- **Visitor SMS costs** are billed separately by the SMS provider (see § 4) and either passed through to the customer or included in the tier price depending on margin analysis. (See [Pricing addendum](#))

2 — Data Model / Schema

Proposed Convex document schemas:

accounts

Field	Type	Notes
name	string	Organization display name
stripeCustomerId	string?	Linked Stripe customer
subscriptionTier	enum	"free" · "pro" · "enterprise"
billingEmail	string	Primary billing contact
createdAt	number	Timestamp
settings	object	{ timezone, defaultFormConfig, notificationPreferences }

users

Field	Type	Notes
accountId	string	Foreign key → accounts
role	enum	"admin" · "staff" · "viewer"
email	string	Auth identity (matches Convex auth)
displayName	string	Visible name in the app

Field	Type	Notes
phone	string?	Internal use only — never exposed to visitors
inviteToken	string?	One-time invite link token
invitedBy	string?	User ID of inviter
permissions	string[]	Granular: "forms:edit", "visitors:export", etc.
createdAt	number	Timestamp

locations

Field	Type	Notes
accountId	string	Foreign key → accounts
name	string	Human-readable label (e.g., "Main Entrance", "Youth Wing")
slug	string	Unique URI segment for the public form
formConfig	object	Fields array, conditional logic, welcome template, follow-up sequence, opt-out keywords
qrCodeUrl	string?	Signed, short-lived URL for the generated QR image
customDomain	string?	Enterprise only — white-label domain
customLogoUrl	string?	Enterprise only — branded logo
isActive	boolean	Soft-delete toggle
createdAt	number	Timestamp

visitors

Field	Type	Notes
locationId	string	Foreign key → locations
phone	string	Encrypted at rest (AES-256)
email	string?	
firstName	string	
lastName	string?	
formResponses	object	Key-value map of form field answers
partySize	number?	
isLocal	boolean?	
isMoving	boolean?	

Field	Type	Notes
referredBy	string?	Visitor ID that referred this person
tags	string[]	Manual or auto-applied labels
optInSms	boolean	
optInFollowup	boolean	
gdprConsent	object	{ timestamp, ipAddress, consentTextVersion }
status	enum	"new" · "contacted" · "followed_up" · "member" · "inactive" · "opted_out"
notes	array	Each: { authorId, text, createdAt }
lastContactedAt	number?	
reminders	array	Each: { reminderAt, assignedTo, note, completed }
createdAt	number	Timestamp
updatedAt	number	Timestamp

message_threads

Field	Type	Notes
visitorId	string	Foreign key → visitors
locationId	string	Foreign key → locations
accountId	string	Foreign key → accounts
messages	array	Each: { sender, userId?, text, channel ("sms" \ "app" \ "web"), sentAt }
status	enum	"active" · "archived"
createdAt / updatedAt	number	Timestamps

audit_log

Field	Type	Notes
action	string	"visitor_registered", "sms_sent", "form_updated", etc.
actorId	string?	User who performed the action
resourceType / resourceId	string	Entity affected
metadata	object	Contextual data for the action

Field	Type	Notes
createdAt	number	Timestamp

reminders

Field	Type	Notes
visitorId	string	
assignedTo	string	User ID
reminderAt	number	Timestamp
note	string	
channel	enum	"push" · "email" · "sms"
status	enum	"pending" · "completed" · "dismissed"

payments

Field	Type	Notes
accountId	string	Foreign key → accounts
stripeInvoiceId	string	
amount	number	Cents or smallest currency unit
periodStart / periodEnd	number	Billing period boundaries
status	enum	"succeeded" · "pending" · "failed" · "refunded"

3 — Auth & Session Management

- **Convex Auth** — use Convex's built-in auth providers (email/password, Google, Apple via custom provider).
- **Sessions** — Convex handles server-side session tokens; no manual JWT management.
- **Multi-session tracking** — admins can view and revoke active sessions.
- **Rate limiting** — applied to public auth endpoints (signup, login) to prevent brute-force attacks.
- **Two-factor authentication** — strongly recommended for admin accounts (TOTP via authenticator app).

4 — SMS & Communication Infrastructure

Recommended provider: Twilio. Twilio offers nonprofit/church pricing and solid delivery metrics. Vonage is a viable fallback.

Aspect	Detail
Sending	Backend sends SMS via provider API; staff phone numbers are never exposed.

Aspect	Detail
Receiving	Inbound SMS hits a webhook → routed to the correct message thread by phone number.
Opt-out keywords	STOP, UNSUBSCRIBE, QUIT — processed automatically per TCPA / carrier requirements.
Templates	Pre-approved per location; support template variables ({{first_name}}, {{church_name}}, etc.).
Cost estimate	~\$0.0079/SMS (Twilio US). At 1,000 visitors/month ≈ \$8/mo in SMS costs.
In-app messaging	Expo app uses Convex real-time subscriptions for instant messaging between staff and visitors who message back — no SMS cost for app-originated messages. Note: visitors initiate contact via web form or SMS; staff reply via app or web.

A later analysis should compare passing SMS costs through to the customer vs. bundling into the tier price.

5 — QR Code System

- **Generation:** Server-rendered via a library like `qrcode` (SVG/PNG output).
- **Encoding:** Each QR code contains a signed, short-lived URL:
`https://visit.example.com/r/<slug>?sig=<token>`.
- **Signing:** Prevents tampering. Tokens expire after a configurable period (default 30 days).
- **Admin dashboard:** Preview, download (PNG/SVG), and print-ready PDF export.
- **Tracking:** Each QR scan is logged (anonymized) to feed location-level analytics.
- **Rotation:** Admin can regenerate codes at any time, invalidating previous ones.

6 — Push Notifications

- **Service:** Expo Notifications (wraps FCM on Android, APNs on iOS).
- **Trigger events:** New visitor registration, new inbound message, reminder fire.
- **Recipients:** Account admins and staff only — push tokens are collected during app login. Visitors receive SMS, not push notifications.
- **Preferences:** Users configure notification settings per location and per event type.
- **Fallback:** Email notification if no push token is registered.

7 — Deployment & DevOps

Component	Stack
Frontend (PWA)	Vite + React → Netlify (auto-deploy from <code>main</code> ; preview deploys for PRs)
Backend	Convex (manages its own infra: real-time sync, DB, server functions)
Mobile App	Expo → EAS Build → OTA updates (no store submission required for internal/test builds)

Component	Stack
Environments	Separate Convex prod and staging deployments
CI/CD	GitHub Actions → lint, type-check, unit tests → deploy frontend + backend
Schema migrations	Convex CLI for schema changes and function deployment
Error tracking	Sentry (frontend + backend)
Product analytics	PostHog or LogRocket for session replay
Uptime monitoring	Better Uptime or Pingdom
Transactional email	Resend or Postmark (account invites, receipts, password resets)

8 — Analytics & Reporting

Metric	Description
Total visitors	Count over configurable date range
Unique visitors	Deduplicated by phone or email
Return rate	Visitors who came back / total visitors
Avg party size	Mean attendees per visit
Time-series	Daily, weekly, monthly trends (line chart)
Per-location breakdown	All metrics segmented by location
SMS delivery rate	Sent vs. delivered vs. failed
Opt-out rate	Visitors who opted out / total opted in
Export	CSV and PDF export for church reports and business compliance

9 — Accessibility (WCAG 2.1 AA)

The visitor-facing web form is the primary public surface and must be fully accessible.

- Semantic HTML with proper **<label>** associations.
- Full keyboard navigation (tab order, visible focus indicators).
- Minimum color contrast ratio 4.5:1 for normal text, 3:1 for large text.
- Screen-reader compatible (ARIA labels, live regions for dynamic content).
- Touch targets minimum 44 × 44 px on mobile.
- Tested with VoiceOver (iOS), TalkBack (Android), and NVDA on desktop.

This is especially important for older church demographics.

10 — Offline / PWA Support

Visitors may register in areas with poor connectivity (basement fellowship halls, rural churches).

- **PWA configuration** — service worker caches form assets for offline access.
- **Local queue** — form submissions are stored locally and auto-synced when connectivity returns.
- **Admin caching** — recent visitor list is cached in the mobile app for offline viewing by staff.

11 — Data Retention & Legal Compliance

Topic	Detail
Retention period	Default 12 months after last contact. Configurable per account (Enterprise: custom retention).
Right to erasure	Reply STOP or use the web form → data deletion request. Admin notified; full purge within 72 hours.
Data export	Visitors can request a copy of all personal data (GDPR Art. 20).
Consent logging	Every opt-in captures timestamp, IP address, and consent-text version.
DPA	Standard Data Processing Agreement provided for Enterprise customers.
Church vs. business	Legal obligations differ by jurisdiction (e.g., pastoral exemptions in some EU interpretations). Recommend formal legal review.

12 — Multi-Language / i18n

- Use **i18next** (or similar) for all visitor-facing strings.
- Admin selects a default language per location.
- SMS templates also require i18n support.
- **Priority languages for launch:** English, Spanish (largest US church demographic need).

13 — Abuse Prevention & Security

- **Rate limiting** on visitor form submissions (per IP and per phone number).
- **CAPTCHA** (hCaptcha or reCAPTCHA) on all public visitor forms.
- **Content moderation** — flag or block submissions containing URLs, profanity, or suspicious patterns.
- **SMS abuse monitoring** — auto-block inbound numbers after N flagged messages.
- **Encryption** — all visitor PII encrypted at rest (AES-256). Phone numbers never logged in plaintext in server logs.

14 — Roadmap Phasing

Phase 1 — MVP (Weeks 1–10)

- Core auth (email/password + Google OAuth)

- Single location, single form
- QR code generation and visitor registration
- SMS welcome message (Twilio)
- Basic admin dashboard (web)

Phase 2 — Viable Product (Weeks 11–18)

- Multi-location support
- Custom form builder with conditional logic
- In-app messaging (Expo + Convex real-time)
- Reminder system
- Analytics dashboard
- Multi-user accounts and role management

Phase 3 — Growth (Weeks 19–26)

- Subscription billing (Stripe)
- White-label / custom branding (Enterprise tier)
- Multi-language support
- Advanced export and reporting
- PWA offline support

Phase 4 — Scale (Ongoing)

- Public API for third-party integrations (CRM, church management software)
- Mobile app improvements (rich notifications, offline mode)
- AI-assisted follow-up suggestions
- Referral tracking program

Summary of Changes vs. Original Draft

The original draft correctly identified the core concept, user entities, and basic flow. The following gaps were filled:

Area	Status
Subscription / pricing model	Three-tier structure defined
Full data model / schema	All entities with fields and relationships
Auth and session management	Convex Auth + 2FA + session revocation
SMS provider and cost estimate	Twilio recommended with per-message pricing
Rate limiting and abuse prevention	Added section
QR code generation and tracking	Full specification
Deployment and DevOps plan	Netlify + GitHub Actions + monitoring stack
Analytics and reporting	Dashboard spec with export

Area	Status
Push notification details	Expo Notifications + email fallback
WCAG 2.1 AA accessibility	Checklist for visitor form
Offline / PWA support	Service worker + local queue
GDPR / data retention policy	Concrete retention, erasure, and consent spec
Multi-language / i18n	Added section
Phased roadmap	4 phases spanning ~26 weeks

Next Steps

- 1. Confirm Twilio vs. Vonage pricing at projected volume.
- 2. Engage legal counsel on GDPR compliance, particularly pastoral exemptions.
- 3. Decide on Stripe vs. Paddle for billing (Paddle handles tax compliance automatically).
- 4. Prototype the visitor form in Vite to validate UX before backend integration.
- 5. Conduct early user testing with 2–3 local churches before public launch.